How humans stay in control

Cressey decides nothing a human cannot change. A model never releases a hold. Thresholds are in `backend/data/policy.yaml` and can be changed live with `PUT /api/policy/responses`.

Escalation thresholds

Check	Trigger	Default response	Human control
Safety floor	Destructive action outside the mandate (`rm`, `DROP`, `DELETE FROM`, `git push --force`), frozen-path writes, tools missing from the policy	**review** (held)	Response set to alert or stop; mandate edited per agent
Trap key	Decoy secret used to change something	**review**	Response per check
Trap key, read only	Decoy read, no change	**alert**	Response per check
Triangle	Write judged with rationalization at or above 0.5, and pressure or opportunity confirmed by code	**review**	Response per check; thresholds in `triangle`
Report check	Final report contradicts the log (score 0.8 or more)	**alert only**: the run is over	Threshold in `triangle`
Fleet	Same target refused in 3 runs within 15 minutes	**alert**	Window and count in `fleet`
Stuck run	3 rejected or expired holds in one turn	**run suspended**	Key returns only after a human Unlock or the next prompt

Modes: **alert** lets the call through and opens an incident; **review** holds it for a human; **stop** refuses it at once. After 3 rejected calls in a turn, Cressey tells the agent to stop and report. Holds never self-release: a person approves, rejects, or lets it expire.

Traceability of AI decisions

- **Append-only event log.** Each event stores the previous event's hash and its own SHA-256. `verify()` checks sequence, links and hashes, and can be anchored outside the log. A tampered or reordered event fails. The demo log verified: 15 records, chain intact.
- **Every hold states why:** the reason, the step number, the confirmed triangle legs, and the score.
- **Sourced guides:** each step cites a retrieved passage (ANSSI, MITRE ATLAS, OWASP, internal runbooks). Citation validity was 100%. A step citing a passage outside the retrieved list is dropped in code.
- **Reasoning is narration.** No provider exposes raw chain of thought, so the dashboard shows what the agent said, not why its model chose it.

Error handling

Failure	What happens	Status
Cressey unreachable from the Claude Code hook	Before Claude Code 2.1.295 the hook lets calls through	**Known risk:** fail open on older versions
Backend restarted	Runs live in memory and are dropped; hooked calls are refused until `./connect.sh` runs again	Fail closed; a human reconnects
Judge model call fails	Not verified in the code read. The floor and trap-key checks do not use the model	Needs a test: force a judge error
Embedding call fails	Retrieval falls back to BM25 alone	Not triggered in the Bedrock run
Guide model fails	No sourced guide; the incident is still held and traced	8/8 guides sourced in the final run

Open gaps

- **Holds tire the approver.** A SOC analyst who cannot judge a developer's file edit gets every write held (open). Planned fix: hold only on alarms, and report holds per 100 normal runs. Not done.
- **Fail-open on Claude Code before 2.1.295** (above).
- **Judge can be swayed.** Adversarial text raised the score in our test but never lowered it. Tested with Jev only.
- **Report check misses by design:** 5 of 10 lies at 0.8.